DOC ID: SEC-GAP-ROADMAP-2026-V1
TARGET SPEC: SentinelAI (August 2026)
STATUS: IN-PROGRESS AUDIT

Sential AI — تقرير الفجوات الهندسية والميزات المتبقية

وثيقة حصر الميزات المعمولة جزئياً، المتطلبات المعلقة، والأفكار الابتكارية الأربعة (أكتوبر 2026)

+16	5	5	4
ميزة مكتملة بالكامل (%100)	ميزات معمولة جزئياً (Partial)	ميزات مجدولة (Roadmap)	أفكار ابتكارية نوعية جديدة

1 الميزات المعمولة جزئياً وتحتاج إكمالاً هندسياً (Partially Implemented)

5 ميزات تحت التنفيذ

1. الترقيع التلقائي بضغطة زر وإنشاء Pull Request على GitHub

FEAT-PR-01 — معمول جزئياً %55

✅ **ما تم إنجازه حالياً في الكود:**

تم بناء خدمة `GitRemediationService.ts` التي تولد Unified Diff دقيق، وتصلح كود الثغرات لـ SQLi و XSS و Command Injection وتكتب التعديل على القرص المحلي مباشرة وتحدث حالة الثغرة لـ FIXED.

❌ **ما ينقص لإتمامها 100%:**

الربط السحابي بـ **GitHub REST API / Octokit** عبر GitHub App أو Personal Access Token، بحيث يقوم السيرفر بإنشاء Branch جديد ورفع Commit وفتح Pull Request رسمي بنقرة واحدة من لوحة التحكم.

2. شجرة مسارات الهجوم البصرية التفاعلية (Interactive Visual Attack Graph)

FEAT-GRAPH-02 — معمول جزئياً %45

✅ **ما تم إنجازه حالياً في الكود:**

محرك الربط `correlateAndValidateFindings` يقوم بالربط المنطقي بين ثغرات الـ DAST ومصادر الـ SAST ويخزن مسارات الهجوم في حقل `relatedFindingsJson` بقاعدة البيانات.

❌ **ما ينقص لإتمامها 100%:**

بناء لوحة العرض البصري (Visual DAG Graph) باستخدام مكتبات **D3.js** أو **Cytoscape.js** لعرض مسار الاختراق المتسلسل من نقطة البداية (Entrypoint) مروراً بالخوادم وحتى قواعد البيانات.

3. محاكاة أثر إغلاق الثغرة ("What If Fixed?") (Simulation)

`FEAT-SIM-03` معمول جزئياً 40%

✅ **ما تم إنجازه حالياً في الكود:**

حساب الـ Root Cause والـ Vulnerability Grouping يجمع الثغرات المشتركة تحت سبب جذري واحد في `findings-deduplication.service.ts`.

❌ **ما ينقص لإتمامها 100%:**

واجهة محاكاة رقمية تتيح للمستخدم تحديد ثغرة أو مجموعة ثغرات وحساب: *"كم مسار هجوم سيتم إغلاقه؟ وكيف سترتفع درجة أمان الموقع من 60% إلى 85% بعد الترقيع؟"*.

4. فحص الصلاحيات المتقدم (BOLA / IDOR Multi-User Matrix)

`FEAT-BOLA-04` معمول جزئياً 50%

✅ **ما تم إنجازه حالياً في الكود:**

خدمة `IdorAuditorService.ts` تفحص التلاعب بالمعرفات الرقمية المتسلسلة (`originalId + 1`) في الروابط والـ APIs وترصد استجابات الـ 200 بدون تصريح.

❌ **ما ينقص لإتمامها 100%:**

مصفوفة اختبار بحسابين حقيقيين مختلفين (Session User A vs Session User B) وتبديل التوكنات للتأكد من استحالة وصول المستخدم الأول لبيانات وسجلات المستخدم الثاني.

5. مستويات الشرح التكيفية المباشرة (Adaptive Explanation Levels Toggle)

`FEAT-ADAPT-05` معمول جزئياً 60%

✅ **ما تم إنجازه حالياً في الكود:**

يتوفر تقرير تنفيذي مبسط للإدارة، وتقرير تقني للمهندسين، وشات AI يجيب ويفهم مختلف الأسئلة ويوضح التفاصيل.

❌ **ما ينقص لإتمامها 100%:**

إضافة مفتاح تبديل فوري (Toggle Switch) في تفاصيل كل ثغرة بالواجهة يبدل الشرح فوراً بين 3 مستويات: **Beginner / Developer / Security Engineer**.

2 الميزات التي لم تُبنَ بعد والأفكار الابتكارية الأربعة (Roadmap & Innovations)

ميزات غير مسبوقة عالمياً

💡 1. محرك ترجمة نوايا الأمان (Security Intent Compiler)

INNOV-INTENT-01

غير مبني 0% (جديد تماماً)

🎯 فكرة الميزة والقيمة المضافة:

بدلاً من الاقتصار على فحص الثغرات العامة، يتيح لصاحب الموقع كتابة سياسات وقواعد الأمان والبيزنس الخاصة بموقعه بلغة عادية (مثلاً: *"كل يوزر يشوف بياناته هو بس"* أو *"الـ checkout مينفعش يقبل رقم سالب أو صفر"*).

🛠️ المعمارية الهندسية المطلوبة للبناء:

1. مفسر لغوي (NLP / Intent DSL Parser) يترجم النص الطبيعي إلى سيناريو اختبار منطقي.
2. محرك تجارب بحسابين تجريبيين (Test Harness).
3. تقرير امتثال لقواعد البيزنس (Intent Compliance Report) يوثق التزام الموقع بالقاعدة والدليل.

💡 2. المراقبة المستمرة لسطح الهجوم (Continuous Attack Surface Monitoring)

INNOV-MONITOR-02

غير مبني 0% (جديد تماماً)

🎯 فكرة الميزة والقيمة المضافة:

إضافة وضع ثالث بالواجهة بجانب الفحص والترقيع باسم **Monitor**، يحرس الموقع 24/7 بعد انتهاء الفحص والإصلاح، ويرصد أي نشاط مريب أو تغيرات غير مصرح بها.

🛠️ المعمارية الهندسية المطلوبة للبناء:

1. مجدول مهام خلفي دوري (Background Cron Scheduler) لفحص يومي/أسبوعي خفيف غير تدميري.
2. محرك مقارنة الفروقات (Differential Drift Engine) يرصد تغير شهادات SSL، وتغيرات الرؤوس، ومنافذ السيرفر.
3. كاشف الانتكاسات الأمنية (Regression Alerting).

💡 3. نظام التنبيهات الذكي متعدد القنوات (Omnichannel Security Alerts)

INNOV-ALERTS-03

غير مبني 0% (جديد تماماً)

🎯 فكرة الميزة والقيمة المضافة:

فرق الـ DevSecOps والـ SOC لا يجلسون أمام لوحة التحكم طوال الوقت. يتم ربط المنصة بقنواتهم الحية في **Slack, Microsoft Teams, Discord, Telegram** لإرسال بطاقات تنبيه فورية عند حدوث خطر Critical.

🛠️ المعمارية الهندسية المطلوبة للبناء:

1. خدمة موصلات الـ Webhooks المتعددة (`OmnichannelAlertService`).
2. قوالب رسائل غنية (Rich Webhook Cards) تحتوي على درجة الـ CVSS وملخص الثغرة.
3. أزرار تفاعلية (Interactive Action Buttons) لإيقاف الفحص أو كتم التنبيه مباشرة من Slack.

📊 4. محرك تتبع التطور الزمني للثغرات (Security Evolution Engine)

`ROADMAP-EVOL-04` غير مبني 0%

🎯 فكرة الميزة والقيمة المضافة:

تتبع تاريخ الفحوصات المتتالية على نفس الموقع، وتوضيح لماذا ظهرت ثغرة معينة، ولماذا اختفت، وهل عادت للظهور مجدداً بعد ترقيعها.

🛠️ المعمارية الهندسية المطلوبة للبناء:

تخزين سجل تاريخي للتطابق عبر الـ `fingerprint` والـ `CWE` ومقارنة الفحوصات بـ Diff زمني يوضح مسار تحسن الموقع.

💣 5. التنبؤ بسلاسل الهجوم المستقبلية (Vulnerability Chain Prediction)

`ROADMAP-PRED-05` غير مبني 0%

🎯 فكرة الميزة والقيمة المضافة:

التنبؤ بالمخاطر المستقبلية لو تم ترك الثغرة دون علاج، وكيف يمكن دمجها مع ثغرات ثانوية للوصول لـ RCE أو تسريب بيانات كامل.

🛠️ المعمارية الهندسية المطلوبة للبناء:

نموذج ذكاء اصطناعي تحليلي يربط بين نوع الثغرة والبنية التحتية للنظام المستهدف ويولد تقرير أثر استشرافي (Predictive Risk Forecast).

3️⃣ مصفوفة التقييم والجاهزية الشاملة (Gap Analysis Master Matrix)

جدول الأولويات الهندسية

كود الميزة	اسم الميزة والنطاق التقني	نسبة الإنجاز الحالية	الصعوبة الهندسية	المدة المقدرة	درجة الأولوية
`FEAT-PR-01`	One-Click AI Remediation & GitHub PR	55% (محلي فقط)	متوسطة	4 - 6 أيام	عاجلة وقصوى (P0)
`INNOV-ALERTS-03`	Omnichannel Alerts (Slack / Teams / Discord / Telegram)	0%	سهلة - متوسطة	3 - 5 أيام	عاجلة وقصوى (P0)
`INNOV-INTENT-01`	Security Intent Compiler (قواعد البيزنس)	0%	متقدمة جداً	2 - 3 أسابيع	استراتيجية فارقة (P1)
`INNOV-MONITOR-02`	Continuous Attack Surface Monitoring (24/7)	0%	متوسطة	1 - 2 أسبوع	استراتيجية فارقة (P1)
`FEAT-GRAPH-02`	Interactive Visual Attack Graph (D3.js)	45% (بيانات فقط)	متوسطة	5 - 7 أيام	عالية (P1)
`FEAT-SIM-03`	What If Fixed?" Interactive" Simulator	40%	متوسطة	4 - 5 أيام	متوسطة (P2)
`FEAT-BOLA-04`	Multi-User Dual Session BOLA Matrix	50%	متوسطة	5 - 7 أيام	متوسطة (P2)
`FEAT-ADAPT-05`	Adaptive Explanation Levels Toggle (UI)	60%	بسيطة	1 - 2 يوم	متوسطة (P2)
`ROADMAP-EVOL-04`	Security Evolution Engine (تاريخ الفحوصات)	0%	متوسطة	1 - 2 أسبوع	مستقبلية (P3)
`ROADMAP-PRED-05`	Vulnerability Chain Prediction	0%	متقدمة	2 - 3 أسابيع	مستقبلية (P3)

4 خطة التنفيذ المقترحة للمرحلة القادمة (Execution Plan)

3 مراحل متتابعة

المرحلة الأولى: Quick Wins والتكامل الفوري

- **One-Click GitHub PR**: ربط GitHub API لفتح PR تلقائي بضغطة زر.
- **Omnichannel Alerts**: إرسال تنبيهات لحظية لـ Slack و Discord و Telegram.
- **Adaptive Levels Toggle**: إضافة زر تبديل الشرح (Beginner / Developer / Engineer) في الواجهة.

المرحلة الثانية: المراقبة والشجرة البصرية

- **Continuous Monitoring**: إطلاق تبويب "Monitor" وجدولة الفحص الدوري 24/7.
- **Interactive Attack Graph**: رسم شجرة مسارات الهجوم التفاعلية بـ D3.js.
- **What-If Simulator**: محاكاة أثر إغلاق الثغرة على مسارات الهجوم.

المرحلة الثالثة: محرك نوايا الأمان والذكاء العميق

- **Security Intent Compiler**: بناء مترجم لغة البيزنس لاختبارات آلية ببيانات تجريبية.
- **Multi-User BOLA Matrix**: اختبار العزل بحسابين تجريبيين مختلفين.
- **Security Evolution Engine**: تتبع مسار وتاريخ الثغرات والانحدارات الأمنية عبر الزمن.